

1. Introducción al NIST RMF

Objetivo general del RMF

El **Marco de Gestión de Riesgos (RMF)** del NIST proporciona un enfoque estructurado, repetible y medible para gestionar riesgos de seguridad y privacidad en los sistemas de información de una organización.

Etapas del RMF

- Prepare (Preparar)
- Categorize (Categorizar)
- Select (Seleccionar controles)
- Implement (Implementar controles)
- Assess (Evaluar controles)
- Authorize (Autorizar el sistema)
- Monitor (Monitorear continuamente)

Contexto

El paso **“Prepare”** se incorporó en la revisión 2 de la NIST SP 800-37 (2018).

Su propósito es fortalecer la preparación organizacional, reducir la duplicidad y facilitar decisiones de riesgo más efectivas.

Sin una buena preparación, las actividades del RMF pueden ser ineficientes y costosas.

2. El Paso “Prepare” en detalle

2.1 ¿Qué es el paso “Prepare”?

Es el **punto de partida del RMF**, donde la organización:

- Define su contexto de riesgo.
- Asigna responsabilidades.
- Evalúa recursos.
- Establece una estrategia de gestión de riesgos coherente con sus objetivos de misión y negocio.

Se completa **antes del paso “Categorize”**

Sirve de base para todos los pasos posteriores del RMF.

2.2 Objetivos principales

- Mejorar la comunicación entre líderes y equipos técnicos.
- Identificar controles comunes y reducir duplicidades.
- Reducir la complejidad de la infraestructura TI.
- Priorizar activos críticos y sistemas de alto impacto.
- Integrar la gestión de riesgos con las metas estratégicas de la organización.

2.3 Resultados esperados

- Estrategia formal de gestión de riesgos.
- Identificación clara de activos, tipos de información y límites de autorización.
- Roles y responsabilidades definidas (CISO, CIO, propietarios de sistemas, etc.).
- Alineación con:
 - **NIST Cybersecurity Framework (CSF)** → gestión técnica de riesgos.
 - **NIST Privacy Framework (PF)** → gestión de riesgos de privacidad.

3. Componentes del paso “Prepare”

El paso se divide en **dos niveles complementarios**:

Nivel Organizacional

Tarea	Descripción	Resultado esperado
P-1	Funciones de gestión de riesgos	Asignar roles, autoridad y gobernanza del riesgo.
P-2	Estrategia de gestión de riesgos	Define tolerancia al riesgo, métodos de evaluación y respuesta.
P-3	Evaluación de riesgos – organización	Identifica amenazas y vulnerabilidades a nivel global.
P-4 (Opcional)	Líneas base adaptadas y perfiles CSF	Permite ajustar los controles a la realidad de la organización.
P-5	Identificación de controles comunes	Determina qué controles se comparten entre sistemas.
P-6 (Opcional)	Priorización por nivel de impacto	Clasifica sistemas según criticidad y nivel de riesgo.
P-7	Estrategia de monitoreo continuo	Define cómo se medirán y revisarán los riesgos a largo plazo.
P-8	Misión o enfoque de negocio	Conecta los riesgos con los objetivos estratégicos.

Nivel del Sistema

Tarea	Descripción	Resultado esperado
P-9	Identificación de actores del sistema	Define usuarios, administradores y entidades externas.
P-10	Identificación de activos	Determina hardware, software, datos y servicios críticos.
P-11	Límite de autorización	Establece el alcance del sistema a proteger.
P-12	Tipos de información	Clasifica los datos según sensibilidad y privacidad.
P-13	Ciclo de vida de la información	Mapea cómo se crea, usa, almacena y elimina la información.
P-14	Evaluación de riesgos del sistema	Analiza amenazas y vulnerabilidades específicas.
P-15	Definición de requisitos	Establece requisitos de seguridad y privacidad del sistema.
P-16	Arquitectura empresarial	Asegura que el sistema se alinee con la estructura TI organizacional.
P-17	Asignación de requerimientos	Relaciona requisitos con controles específicos.
P-18	Registro del sistema	Formaliza la existencia del sistema y su inclusión en el RMF.

Ejemplos prácticos

Ejemplo 1:

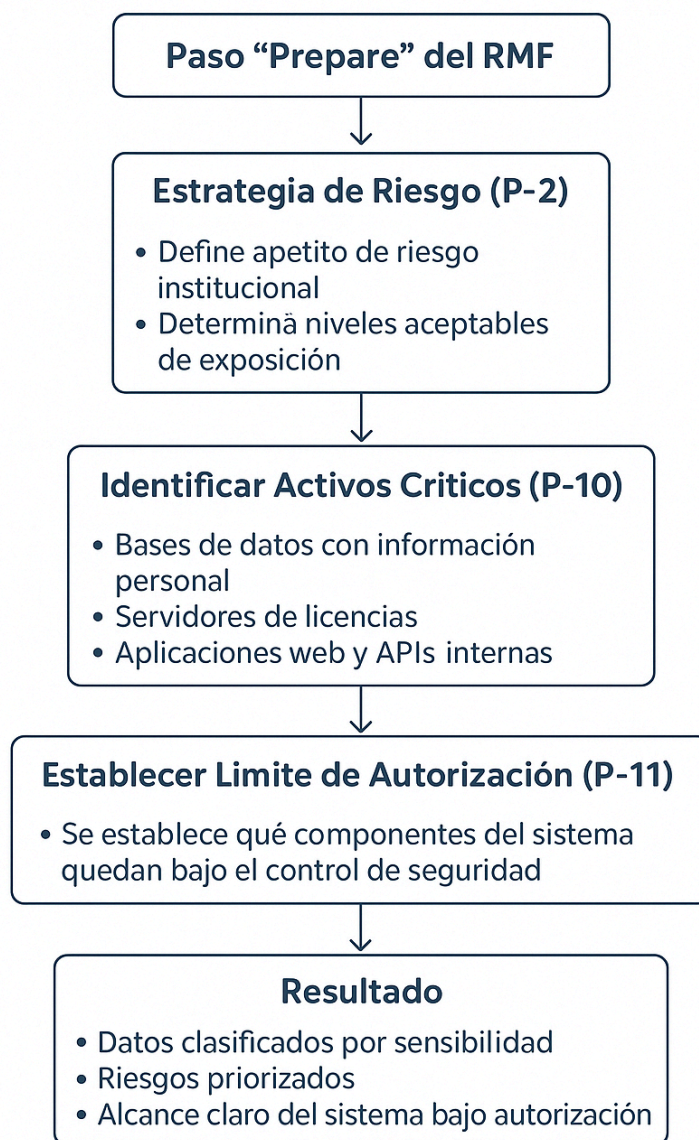
Una agencia gubernamental que maneja datos personales inicia el RMF.

Durante el paso **Prepare**, define su estrategia de riesgos (P-2), identifica activos críticos (P-10), y establece un límite de autorización (P-11) para su sistema de gestión de licencias.

- **Resultado:** cuando avanza al paso “Categorize”, ya tiene claro qué información proteger y qué riesgos priorizar.



Ejemplo 1 – Preparación del RMF en una Agencia Gubernamental



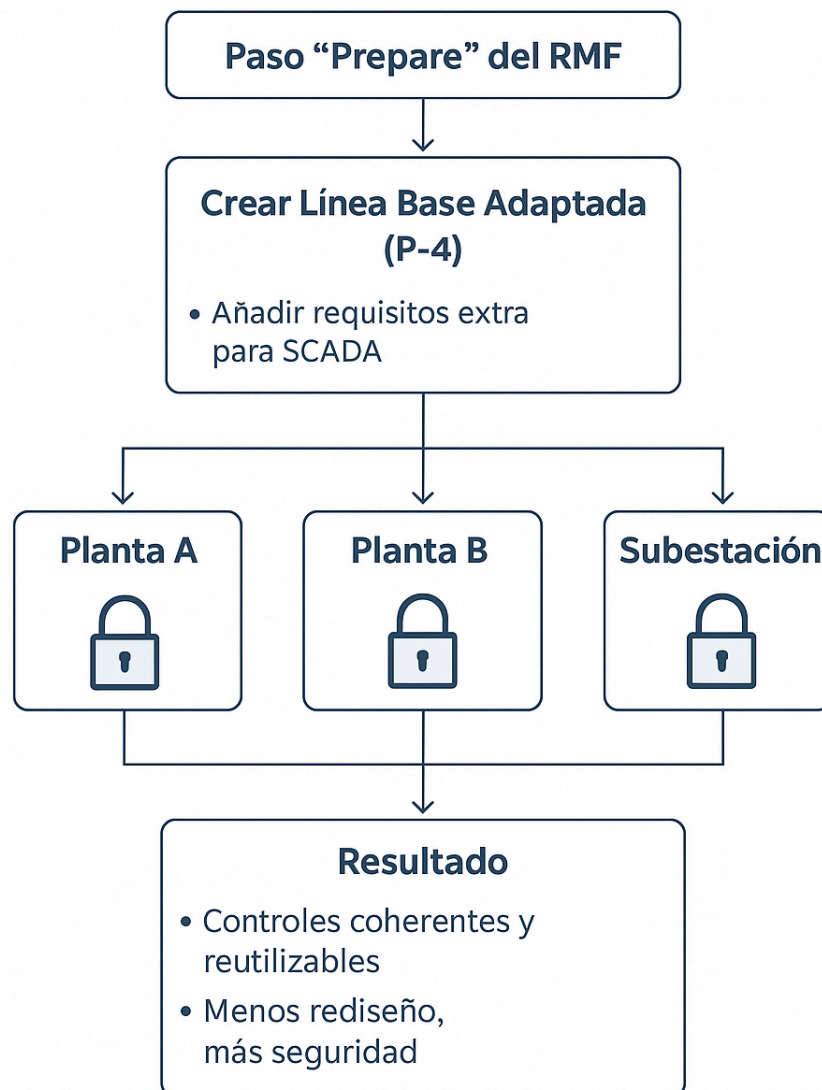
Ejemplo 2:

Una empresa de energía crea una **línea base de control adaptada (P-4)** que incluye requisitos adicionales de ciberseguridad para sistemas SCADA.

Esto evita rediseñar controles para cada planta o subsistema.



Ejemplo 2 – Empresa de Energía y Controles Adaptados



5. Relación con otros marcos

Marco	Cómo se conecta con “Prepare”
NIST CSF	El paso “Prepare” refuerza la función “Identify” del CSF (activos, riesgos, entorno).
NIST Privacy Framework (PF)	Comparte tareas que establecen gobernanza, evaluación de riesgos y tratamiento de datos personales.
OMB A-130	Refuerza los requerimientos federales de gobernanza de información.

6. Actividades sugeridas para la clase

Actividad 1 – Debate grupal

Tema: “¿Qué pasa si una organización omite el paso Prepare?”

- Analizar posibles consecuencias: duplicidad de controles, riesgos no identificados, costos elevados, etc.

Actividad 2 – Caso práctico

Simular la creación de una **estrategia de gestión de riesgos (P-2)**:

- Definir tolerancia al riesgo.
- Establecer roles (CISO, CIO, propietarios de sistema).
- Redactar una política breve de evaluación y monitoreo.

7. Conclusión

El paso “**Prepare**”:

- Es el **fundamento del RMF**.
- Garantiza que la gestión de riesgos sea **eficiente, coherente y sostenible**.
- Permite **alinear los riesgos técnicos con los objetivos estratégicos**.
- Reduce costos, mejora la comunicación y optimiza la protección de datos y sistemas.